



Recommended Exercise Reflection Guide

Use this guide after completing a recommended exercise in the Codex Security, Governance and Controls course.

This guide provides a strong example you can use to assess and improve your own response.

Your response does not need to use the exact same wording. Use the guide to check whether your answer is specific, grounded in the workflow context, and clear about the governance reasoning behind your decisions.

Assess and Improve Your Safeguard Recommendation

Recommended exercise recap

In the recommended exercise **Recommend practical safeguards for a Codex-assisted engineering workflow**, Bridgeford Trent reviews three candidate workflows for Arfon Digital:

- Pull-request evidence preparation.
- Recurring CI failure investigation.
- Deployment workflow support.

Your task is to choose one workflow and define the minimum safeguard set needed to keep it useful, reviewable, and accountable.

Your response should capture:

- The selected workflow.
- The boundary and operating posture.
- What Codex may do.
- What Codex must not do.
- Which actions require configured or customer-defined approval.
- What validation evidence Codex should return.
- Who reviews or escalates the output.
- What should remain visible or auditable.
- Why the safeguard set fits the workflow risk.

Assess your response

Review the example below, then compare it with your own response. The goal is not to copy the wording. The goal is to assess whether your safeguards are proportionate to the workflow risk and customer context.

As you review the example, pay attention to three things:

- The boundary is narrow. The workflow is limited to one selected repository and approved CI failure logs.
- Actions are separated clearly. The example distinguishes what Codex may do, what it must not do, and which actions require configured or customer-defined approval.
- Evidence and visibility are practical. The example names what reviewers need to inspect and what Arfon Digital should be able to trace later.

Worksheet section	Example response
Selected workflow	Workflow B: Recurring CI failure investigation.
Boundary and posture	One selected repository, approved CI failure logs, and relevant failure context. Use a customer-defined proposal-only review process, and require approval before specified edits or broader commands where policy or customer process requires it.
Codex may	Review approved logs, inspect the selected repository, summarize likely root cause, and propose the smallest safe next step.
Codex must not	Merge code, deploy, modify infrastructure, access unrelated repositories, touch sensitive files, or use unapproved tools. Any file-edit restriction should be defined by the configured runtime or the customer's process.
Approval-gated actions	Actions that configured policy, sandbox boundaries, or the customer's process require to pause—for example, specified file edits, commands outside the approved set, expanded repository or tool access, continued work after failed validation, or a move from investigation into implementation.
Validation evidence	Logs reviewed, files inspected, likely root cause, proposed next step, command output or recommended test command, missing evidence, assumptions, and open questions.
Review and escalation	A named engineer or code reviewer inspects the output. Escalate to platform or security if sensitive files, production configuration, unclear ownership, failed validation, or broader system impact appears.
Visibility and auditability	Arfon Digital should be able to see the workflow request, approved boundary, repository scope, Codex output, validation evidence, approval decisions, reviewer decision, and escalation notes.
Safeguard rationale	The workflow can be useful as governed delegation, but it needs a narrow boundary, required evidence, human review, configured approvals for boundary crossings, any customer-defined gate before higher-risk action, and visible escalation records.

Why this example is strong

This example is strong because it selects safeguards from the workflow context instead of listing every possible control.

The response recognizes that recurring CI failure investigation can be useful as governed delegation, but only if the workflow remains bounded. It limits Codex to one selected repository, approved CI logs, and relevant failure context.

The example also separates allowed, restricted, and approval-gated actions. It distinguishes native approval behavior from customer-defined process gates so the workflow does not treat every in-workspace edit as approval-only.

The validation evidence is specific enough for review. A reviewer can inspect the logs reviewed, files inspected, likely root cause, proposed next step, command output or recommended test command, missing evidence, assumptions, and open questions.

The strongest part of the example is the connection between safeguards and accountability. The workflow remains useful because Codex can investigate and propose next steps, but it remains governed because configured boundary crossings, customer-defined higher-risk gates, expanded access, failed validation, and implementation moves require approval or escalation.

Reflect on your own response

Compare your response with the example.

Ask yourself:

- Did I define the smallest safe boundary that still lets the workflow be useful?
- Did I separate what Codex may do from what Codex must not do?
- Did I identify which actions require configured or customer-defined approval?
- Did I name validation evidence a reviewer can inspect?
- Did I include review and escalation ownership?
- Did I explain what should remain visible or auditable?
- Did I avoid over-governing a lower-risk workflow or under-governing a medium-risk workflow?

If your answer is unclear, refine your safeguard recommendation before building the final governance-aware workflow recommendation.